GiCoffee on Gitea, station S4, CSCI 435 Showcase 2

SonarQube Cloud + Gitar

Rule checks and AI review on every PR

Watch our tutorial video
youtu.be/REPLACE_ME

Every check we had passed this PR

PR #152 has four planted problems. `go vet`, `ESLint` and our unit tests passed it. These two didn't:

SonarQube Cloud — **Quality Gate failed**

- 20% Coverage on new code (needs ≥ 80%)
- E Security rating on new code (needs A)
- D Reliability rating on new code (needs A)

Gitar — **Changes requested**

- Security *Open redirect: unvalidated next URL*
- Bug *.sort() sorts numbers as strings*
- Quality *Test has no assertion*
- Quality *New Go handler has no test*

- CI failed *A data race in modules/timeutil. Gitar marked it unrelated to this PR.*

Recreated from **PR #152** in our Gitea repo.

The problem

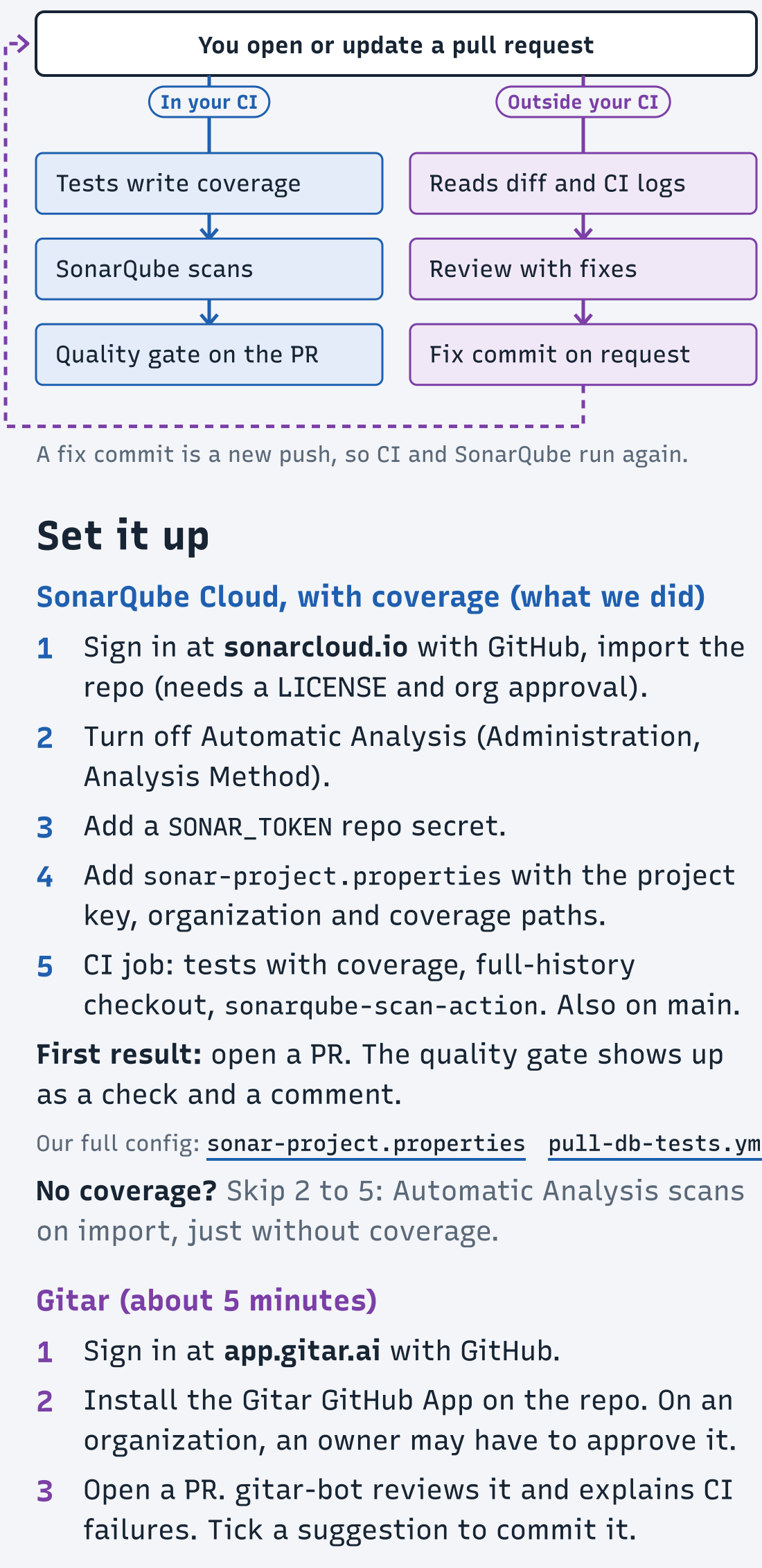
PRs, especially AI-written ones, arrive faster than people can review them, and linters only catch what they're set up to catch. Bugs, security holes and untested code get merged on green checks.

Why not just ask an AI assistant?

	AI chat	SonarQube	Gitar
Runs on every PR by itself	✗	✓	✓
Same result every run	✗	✓	✗
Pass/fail gate	✗	✓	✗
Tracks coverage	✗	✓	✗
Knows your own helpers	if pasted	✗	✓
Fixes failing CI	if pasted	✗	✓

SonarQube sets a measurable bar every PR must meet. Gitar covers what needs judgment and writes the fix.

How they fit together



A fix commit is a new push, so CI and SonarQube run again.

Set it up

SonarQube Cloud, with coverage (what we did)

1. Sign in at **sonarcloud.io** with GitHub, import the repo (needs a LICENSE and org approval).
2. Turn off Automatic Analysis (Administration, Analysis Method).
3. Add a `SONAR_TOKEN` repo secret.
4. Add `sonar-project.properties` with the project key, organization and coverage paths.
5. CI job: tests with coverage, full-history checkout, `sonarqube-scan-action`. Also on main.

First result: open a PR. The quality gate shows up as a check and a comment.

Our full config: `sonar-project.properties` `pull-db-tests.yml`

No coverage? Skip 2 to 5: Automatic Analysis scans on import, just without coverage.

Gitar (about 5 minutes)

1. Sign in at **app.gitar.ai** with GitHub.
2. Install the Gitar GitHub App on the repo. On an organization, an owner may have to approve it.
3. Open a PR. gitar-bot reviews it and explains CI failures. Tick a suggestion to commit it.

`Gitar fix CI`	Fix the failing CI
`gitar auto-apply:on`	Fix without asking (Pro)
`gitar-skip`	Label: skip this PR

When to use them, and when not

SonarQube Cloud

- ✓ A bar every PR must meet, with coverage and ratings tracked over time.
- – Free for public projects and for private ones up to 50k lines. Team plan from $34 a month.
- – Rules don't know your code: it flags Gitea's own redirect check as unsafe.

Gitar

- ✓ Plain-language findings, fixes you can commit, and CI failures sorted into real and unrelated.
- – Free for qualifying open source. Else a 14-day Pro trial, then $20 or $40 per user a month (annual). Auto-apply needs Pro.
- – It's AI, and its fixes can clash with SonarQube: its redirect fix uses that same Gitea check.

Both send your code to a third-party service.

---

sonarcloud.io **docs.sonarsource.com** **gitar.ai**

Versions: both are hosted services with no version number. Our CI runs `sonarqube-scan-action` v8.3.0. Prices checked November 9, 2026.